SENTINELAI • FINAL YEAR PROJECT (FYP2) PRESENTATION BLUEPRINT

Full Report (No. 6) vs Simplified Report (No. 2)

Direct Comparison: Exhaustive Forensic Audit Dossier vs. Fast-Turnaround IT Action Card

FULL REPORT	SIMPLIFIED REPORT
9 Fields	3 Things
Technical Proof	Immediate Fix

6 FULL REPORT FINDING FORMAT
Detailed Technical Finding Dossier

Audience: Pentesters & Auditors

1. SEC-FIND-042 • Vulnerability Title
SQL Injection in Search Query Endpoint

2. CVSS 9.4 CRITICAL

3 & 4. ACADEMIC CLASSIFICATION
CWE-89 • OWASP A03:2021–Injection

5. VULNERABLE SOURCE & ENDPOINT
`/api/v1/search?q= (backend/db.js:142)`

6. TECHNICAL MECHANISM & THREAT THEORY
Dynamic SQL statement concatenation without parameterization enables subquery execution and authentication bypass.

7. EXPLOITATION POC & ATTACK COMMAND

```
curl -i -X GET "https://target/search?q=' UNION SELECT null,username,password_hash FROM users--"
```

8. RAW HTTP EVIDENCE
`HTTP/1.1 200 OK • JSON [{"admin":"hash"}]`

9. DEFENSE BLUEPRINT
Parameterized statements + RFC/CVE links

Philosophy: **Exhaustive Proof & Replication** — 1 of 7 Full Chapters

2 SIMPLIFIED REPORT FORMAT
"Your Fix Cards" (Action Playbook)

Audience: Sysadmins & IT Ops

ACTION ITEM #1 • PLAIN TITLE
Database Query Input Concatenation Flaw

FIX TODAY ~30 MIN

1 SYMPTOM (WHAT WAS FOUND)
"User search queries are inserted directly into database commands without input validation."

2 RISK (WHY IT MATTERS)
"Attackers can bypass the login screen, steal the full customer database, or delete stored records."

3 PRESCRIPTION (HOW TO FIX)

```
db.query("SELECT * FROM users WHERE name = $1", [userInput])
```

✓1-Step Verification: Test search with quote `'` & confirm HTTP 200 without SQL error.

Philosophy: **Instant MTTR & Zero Jargon** — 1 of 3 Simple Stages

CONTEXT IN DOCUMENT: **Full Report:** 7 Total Chapters (Cover, TOC, Exec Summary, Methodology, OWASP, **No. 6 Findings**, Appendix)

Simplified Report: Only 3 Stages (1. SLA Posture, **No. 2 Fix Cards**, 3. Sign-off Checklist)